



Seguridad y cumplimiento en la nube

Cierre de Unidad 1 — antes del Parcial 1

Ing. Rodolfo Cañas Cervantes

Universidad de la Costa (CUC) · Ingeniería de Sistemas

Semana 5 · Periodo 2026-2 · Barranquilla, Colombia

Modelo de responsabilidad compartida

Quién asegura qué — la división cambia según el modelo de servicio (IaaS / PaaS / SaaS).

Lo que asegura EL PROVEEDOR

Centros de datos · hardware · virtualización · red física · refrigeración · energía
Cumplimiento de la nube en sí misma (edificios, personal, redundancia)

Lo que aseguras TÚ

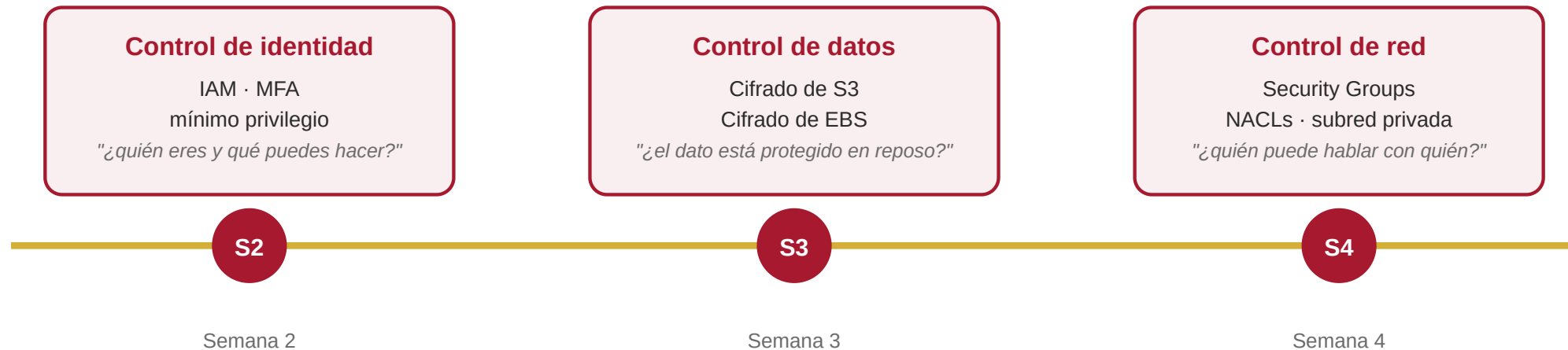
Datos · identidad y accesos (IAM) · configuración de red y firewalls
Sistema operativo del huésped (en IaaS) · aplicación · cifrado de tu lado

el reparto se desplaza según el modelo: **en IaaS aseguras más, en SaaS menos**

El modelo es el mismo en cualquier proveedor; en este curso se practica sobre AWS Academy.

Ya construiste seguridad sin llamarlo así

Recapitulación: tres conceptos ya vistos, ahora nombrados como controles de seguridad.



Hoy los reunimos bajo un solo marco: **defensa en profundidad** — cada capa contiene el daño si la anterior falla.

Defensa en profundidad

Ninguna capa sola basta — si una falla, la siguiente debe contener el daño.



Cada capa asume que la exterior ya fue vulnerada — el ataque se detiene en la siguiente.

Cifrado: en tránsito vs. en reposo

El dato tiene dos vidas — protegerlo en ambas.

En tránsito

Protege el dato mientras viaja por la red — entre el usuario y la nube, entre servicios internos.

Mecanismo estándar: HTTPS / TLS (el candado del navegador).

En AWS: todo endpoint público usa TLS; dentro de la VPC el tráfico también puede ir cifrado punto a punto.

En reposo

Protege el dato guardado — en disco, en object storage, en backups.

Mecanismo estándar: AES-256 con claves gestionadas por el proveedor (KMS).

En AWS: S3 y EBS cifran por defecto; las claves pueden ser gestionadas por AWS o por ti.



CASO APLICADO · CORPORACIÓN INDUSTRIAL DEL CARIBE

Sus bases de datos SAP viajan cifradas (TLS) hacia la nube y se guardan cifradas en reposo (KMS) — las dos vidas del dato, las dos protegidas.

Identidad, otra vez, más a fondo

Mínimo privilegio + políticas explícitas + MFA obligatorio.

Las 3 reglas que siempre se cumplen

Mínimo privilegio: cada identidad recibe solo los permisos que necesita para su tarea — nada más. Se revisa periódicamente.

Políticas explícitas Allow / Deny: en AWS IAM todo se escribe como JSON; si no hay Allow explícito, el acceso está denegado. **Deny explícito siempre gana** sobre cualquier Allow.

MFA obligatorio para privilegio alto: cualquier rol con permisos de administración, eliminación o acceso a datos sensibles exige segundo factor — sin excepción.

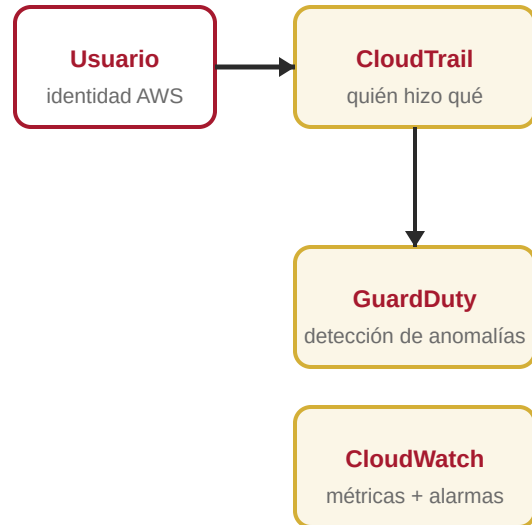
```
// Ejemplo: política que permite SOLO lectura en un bucket
{
  "Effect": "Allow",
  "Action": "s3:GetObject",
  "Resource": "arn:aws:s3:::reportes/*"
}

// Deny gana sobre Allow — para excluir una carpeta sensible:
{
  "Effect": "Deny",
  "Action": "s3:*",
  "Resource": "arn:aws:s3:::reportes/confidencial/*"
}
```

IAM (AWS Identity and Access Management) es el servicio que ya usaste en el lab — el mismo concepto aplica a cualquier nube con otro nombre comercial.

Visibilidad: si no lo registras, no lo puedes investigar

Logging centralizado + alertas por actividad anómala — la base de toda auditoría forense.



Ejemplo concreto en AWS (la plataforma del lab): estos 3 servicios cubren la tríada **registrar** · **detectar** · **alertar**.

CloudTrail — registra cada llamada a la API de AWS: *quién hizo qué, cuándo y desde dónde*. La base de cualquier investigación forense.

GuardDuty — analiza los logs continuamente y levanta alertas cuando aparece actividad anómala (intentos de acceso desde IPs raras, llamadas a APIs que nunca se habían hecho).

CloudWatch — métricas de rendimiento (CPU, latencia, errores) y alarmas que disparan notificaciones o acciones cuando se cruza un umbral.

Regla operativa: si un incidente no aparece en los logs, no se puede investigar — y a veces ni siquiera se sabe que ocurrió.

Cumplimiento: por qué no es solo checklist técnico

Mover los datos a la nube no exime a la empresa de las leyes que aplican en su jurisdicción.

EJEMPLO LOCAL · COLOMBIA

Ley 1581 de 2012

Habeas data — toda empresa que trate datos personales en Colombia debe:

- Recolectar solo lo necesario
- Informar al titular el uso
- Permitir al titular actualizar o eliminar
- Asegurar el dato donde esté

El error común

"Subimos los datos a AWS / Azure / GCP y con eso ya cumplimos" → **FALSO**. La jurisdicción del dato sigue siendo donde está el titular. Si el cliente es colombiano, la ley colombiana sigue aplicando — la nube no la borra.

Para el ingeniero: diseñar con cifrado en reposo + en tránsito, logging activo y control de accesos — eso facilita cumplir cualquier auditoría.

Para el equipo legal / gerencia: revisar qué leyes aplican a los datos de los clientes antes de elegir región del datacenter y antes de firmar contratos de procesamiento con el proveedor.

Lo que cambia entre nubes: la región donde se guardan los datos y los mecanismos de auditoría que el proveedor expone — el cumplimiento legal es siempre responsabilidad de quien usa la nube.

El pilar de seguridad del Well-Architected Framework

AWS Well-Architected = 6 pilares; seguridad es el que vimos hoy en profundidad.

El framework se introdujo en la semana 1; hoy profundizamos el pilar de seguridad.

Identidad fuerte

MFA, mínimo privilegio,
identidades federadas

Trazabilidad

Logs centralizados, auditoría,
alertas

Protección en todas las capas

Defensa en profundidad, cifrado

Automatizar buenas prácticas

Políticas como código, guardrails

Prepararse para incidentes

Runbooks, simulacros, respuesta
definida

Los 5 principios del pilar de seguridad se cumplen, en la práctica, con lo que ya aprendiste: **IAM, Security Groups, cifrado y CloudTrail.**

Caso aplicado: Corporación Industrial del Caribe

Su arquitectura on-premise actual tiene 3 riesgos concretos — qué cambiaría al migrar con lo visto hoy.

Riesgo on-premise

Sin segmentación real entre DMZ y LAN — un atacante que entra a la red interna ve todo.

Backups sin cifrar — un disco robado del datacenter expone toda la historia clínica / datos de clientes.

Un solo administrador con acceso total — si su contraseña se filtra, todo se pierde.

Qué cambia con la migración a la nube

Subred pública + subred privada en VPC, separadas por tablas de rutas — la base de datos nunca queda expuesta a internet.

Cifrado en reposo por defecto en S3 y EBS (AES-256) — el dato robado es ilegible sin la clave.

MFA + mínimo privilegio + Deny explícito en IAM — un admin no tiene que ser root, cada quien recibe solo lo que necesita.

Puente directo al Proyecto de Aula: la **documentación de planificación** que entregan el 12 de septiembre debe nombrar estos 3 riesgos y proponer cómo cada control los cubre.

Cierre de Unidad 1

Qué sigue — y qué entregamos antes del Parcial 1.

Semana 6 · Parcial 1

20% de la rúbrica. Se libera esa semana + 70% examen práctico en vivo. Cubre todo lo visto en S01–S05: fundamentos, despliegue, identidad, almacenamiento, redes y seguridad.

Lo que entregamos entre hoy y el parcial

12 de septiembre — documento de planificación del Proyecto de Aula (Corporación Industrial del Caribe).

Laboratorios AWS completados (sitio estático en S3 + red VPC, según calendario).

Mensaje para llevar

En la nube la seguridad **no es un producto que se compra y se instala**: es una **disciplina de diseño** que se aplica en cada decisión — qué datos subes, qué región, quién accede, qué se registra, cómo respondes.

Repaso antes del parcial: releer las notas de S01 a S05 + repasar los laboratorios. Los servicios que aparecieron nombrados en clase son los que entran: **EC2, S3, VPC, IAM, Security Groups, NACL, NAT Gateway, CloudTrail.**

Nos vemos en el Parcial 1 — y luego empezamos Unidad 2.